

Medium:

M1: Kerberoasting

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting	
	Mitigations	M1041: Encrypt Sensitive Information M1027: Password Policies	
Affected Scope			

Description

An attacker with a valid, low-privileged domain user account can request encrypted tickets for services running on servers. The machine did not have randomized or secure service account passwords, allowing the attacker to then take them offline and use brute-force techniques to crack the password.

Business Impact

This allows an adversary to compromise a service account, which can lead to a data breach, lateral movement across the network, and potential domain compromise if the account has high privileges. They can also cause severe operational disruption by modifying the service that the service account controls.

Steps to Reproduce

Step 1: Enumerate the Active Directory for accounts with Service Principal Names (SPNs) via Bloodhound.

Step 2: Request service tickets for the discovered SPN accounts using GetUserSPNs from Impacket.

Step 3: Export the tickets to a file

Step 4: Crack the ticket hashes offline using a tool like HashCat and wordlist like rockyou.txt to recover the password.

Remediations

Team-XX recommends the following:

1. Enforce a strong password policy for all service accounts to prevent hash cracking after Kerberoasting.
2. Disallow user accounts from having a Service Principal Name (SPN) and implement the principle of least privilege to limit service account permissions.
3. Implement Windows Defender or another Antivirus solution to detect and prevent common AD attacks.

References

[Microsoft 365 Security - Kerberoasting](#)

M1: Plaintext Passwords in Database

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.8	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1552: Unsecured Credentials</u> <u>T1555: Credentials from Password Stores</u> <u>T1005: Data from Local System</u>	
	Mitigations	<u>M1041: Encrypt Sensitive Information</u>	
Affected Scope			

Description

Passwords in the database are stored in plaintext allowing attackers to easily find user passwords.

Business Impact

An attacker can leverage this vulnerability to log in and impersonate users, accessing sensitive information and making changes under their name.

Steps to Reproduce

Step 1: Login to the database

Code block here `mysql -u admin -p`

Step 2: Access the database

Code block here `use wp-database`

Step 3: View the stored passwords

Code block here `SELECT Passwords FROM User_Data;`

Remediations

Team-XX recommends the following:

1. Stored passwords should be encrypted using a strong resource intensive hash method that is hard to brute force.
2. Consider using a pepper and a salt to increase the difficulty to crack.

Resources

[OWASP - Password Storage Cheat Sheet](#)

M1: Public Access to WP-Cron.php

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.8	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application	
	Mitigations	M1054: Software Configuration M1042: Disable or Remove Feature or Program	
Affected Scope			

Description

WP-Cron.php is a script to schedule and run background tasks on WordPress to automate tasks including post publishing, update checking, and sending email notifications. An attacker can exploit this script by repeatedly sending requests to WP-Cron, causing it to consume large number of requests, eventually crashing the website in a Denial-of-Service attack.

Business Impact

An attacker can leverage Denial Service (DOS) attack. This will cause server performance to be impacted and could cause the website to become unavailable due to a high number of resources being used by the attacker, impacting the availability of the WordPress server.

Steps to Reproduce

As this penetration test was run against the live production environment, Team-XX

Remediations

Team-XX recommends the following:

1. Block any external IP address from accessing WP-Cron.php by explicitly denying all incoming requests in the .htaccess file.
2. If the WP-Cron service is not in use or required, it is highly recommended to disable the feature to reduce attack surface.

Resources

[In-Motion Hosting: WP-Cron Security Management](#)

M1: Server-Side Request Forgery

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.3	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		<u>AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:L/SI:N/SA:L</u>	
MITRE ATT&CK	Techniques	<u>T1190: Exploit Public-Facing Application</u>	
	Mitigations	<u>M1035: Limit Access to Resource Over Network</u> <u>M1048: Application Isolation and Sandboxing</u> <u>M1016: Vulnerability Scanning</u>	
Affected Scope			

Description

Server-Side Request Forgery (SSRF) is a web vulnerability that allows an attacker to have a server-side application send requests to an unintended location. An attacker can fetch content from an external URL and trick the application into making requests to internal services or resources that are not normally accessible from the outside.

Business Impact

An attacker successfully exploiting SSRF can map the internal network and possibly access sensitive data from internal services. They can steal sensitive information and cause financial and reputational damage to the APT organization.

Steps to Reproduce

Step 1: View the application function **X** on **X** and see that it takes a user-supplied URL as input.

Step 2: Replace the legitimate external URL with a URL pointing to a service controlled by yourself and verify that the server makes an outbound request.

Step 3: Attempt to access internal IP addresses like **X** and view internal services.

Remediations

Team-XX recommends the following:

1. Validate user input by implementing a whitelist of allowed domains, IP addresses, and protocols that the application is permitted to request. Validate all user-supplied URLs against this list.
2. If a whitelist is not possible to implement, implement a blacklist of disallowed domains, IP address, and protocols.

References

[OWASP – Server Side Request Forgery \(SSRF\)](#)

[Portswigger – What is SSRF?](#)

M1: Kiosk Breakout

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.9	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1611: Escape to Host	
	Mitigations	M1026: Privileged Account Management M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

An attacker is able to breakout of their restricted environment and access the underlying computer environment.

Business Impact

Successfully breaking out of the kiosk allows an attacker to access potentially private documents on the machine, and might allow them to escalate to higher privilege users and gain more control over the network.

Steps to Reproduce

Step 1:

Remediations

Team-XX recommends the following:

1. Run the kiosk as a restricted user with fewer permissions.

References

[NVISO Labs: Breaking out of Windows Kiosks](#)

M1: Weak Password Policies

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N</u>	
	Techniques	<u>T1110.003: Password Spraying</u>	

MITRE ATT&CK	Mitigations	M1036: Account Use Policies M1032: Multi-Factor Authentication M1027: Password Policies
Affected Scope		

Description

The affected host's user accounts was found to be using a weak password that was successfully guessed using a dictionary-based brute force password attack. This led to compromise of the ____ account.

Business Impact

This vulnerability can lead to operational disruptions and data leakage as an attacker that knows the credentials for a user can impersonate them and modify resources under their control.

Steps to Reproduce

Step 1: Run a bruteforce attack using the rockyou wordlist against the user using ffuf.

Remediations

Team-XX recommends the following:

1. Implement and enforce a strong password policy for all accounts to ensure attackers are unable easily brute force passwords. As a baseline the following minimum password policy is recommended:
 - a. Minimum of 12 characters
 - b. At least one uppercase character, one lowercase character, one digit character, and one special symbol.
 - c. Unique passwords for each user and service to prevent password reuse
2. Implement a lockout policy to block attackers after repeated failed login attempts, preventing them from brute forcing credentials.
3. Implement multi-factor authentication to prevent access even with leaked or disclosed passwords.

References

[DigiCert - Creating Password Policy Best Practices](#)

[Linode - Fail2Ban for SSH Brute-force Protection](#)

[Palo Alto Networks - Multi Factor Authentication](#)

M1: Password Reuse

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1110.003: Password Spraying	
	Mitigations	M1036: Account Use Policies M1032: Multi-Factor Authentication M1027: Password Policies	
Affected Scope			

Description

Multiple accounts on the network were found to be using the same password.

Business Impact

This vulnerability can lead to operational disruptions and data leakage as an attacker that knows the credentials for a user can gain access as other users in the network and impersonate them and access resources under their control.

Steps to Reproduce

Step 1: Attempt to use the password for user X for user Y

Remediations

Team-XX recommends the following:

1. Insure that a password policy is enforced preventing users from sharing a password.

References

[DigiCert - Creating Password Policy Best Practices](#)

[Palo Alto Networks - Multi Factor Authentication](#)

M1: Cookie Manipulation

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>Forge Web Credentials: Web Cookies</u>	
	Mitigations	<u>M1041: Encrypt Sensitive Information</u>	
Affected Scope			

Description

The web application stores user authorization roles in a client-side cookie and uses this value to determine access levels. An attacker can modify the cookie value from guest to administrator, and the server accepts the modified value without verification, granting administrative access to the web server.

Business Impact

This vulnerability can allow for a low-privileged or unauthorized user to gain administrator access to the web-server. This could allow them to view sensitive information, including other user data, alter sensitive information, or take down or change the web-server.

Steps to Reproduce

Step 1: Authenticate as a guest user

Step 2: Observe the cookies set in browser dev tools

Step 3: Alter 'Guest' to 'Admin'

Step 4: Reload the page and observe admin panel is now visible

Remediations

Team-XX recommends the following:

1. Do not store role or permission data as mutable, plaintext cookies on the client-side. Store only a server-generated session identifier and maintain authoritative user/role permission on the server-side.
2. Remove any logic that grants admin access purely based on unsigned cookie values.
3. Use signed tokens (JWT) and always validate the signature and claims server-side
4. Set the cookie to have the *Secure* flag

References

[MITRE: CWE - Reliance on Cookies without Validation and Integrity Checking](#)

[OWASP - Testing for Cookie Attributes](#)

M1: Windows Defender Disabled

Matrix Calculation		CVSS Score	Risk
Impact	Medium	N/A	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1562.001:Impair Defenses - Disable or Modify Tools	
	Mitigations	M1047: Audit M1050: Exploit Protection	
Affected Scope			

Description

The machine has its native anti-malware software, Windows Defender, in particular, Real-Time Protection, disabled. This removes the primary defense layer of the machine, leaving the system exposed to common attacks.

Business Impact

An attacker can successfully compromise the machine with much less difficulty, which makes the machine an easy target for malware infection. A compromise can result in the theft of sensitive data and allow attackers to launch further attacks against other systems within the internal network.

Steps to Reproduce

Step 1: Log into the affected Windows machine with a user.

Step 2: Open PowerShell and run 'Get-MPCComputerStatus' and observe that the RealTimeProtectionEnabled option is set to 'false'.

Remediations

Team-XX recommends the following:

1. Enable Windows Defender and ensure that 'Real-time protection', 'Cloud-delivered protection', and 'Tamper protection' are enabled on the host.

2. Set the correct Windows Defender settings via Group Policy Objects (GPO) to enforce it across a domain environment, preventing users from disabling it and ensuring a consistent security posture.

References

[Microsoft - Microsoft Defender Antivirus in the Windows Security App](#)

M1: Insecure Direct Object Reference (IDOR)

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.3	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1567: Exfiltration Over Web Service</u> <u>T1213: Data from Information Repositories</u>	
	Mitigations	<u>M0801: Access Management</u> <u>M0800: Authorization Enforcement</u>	
Affected Scope			

Description

The machine hosts a webserver that exposes object identifiers (ID) in URLs or API parameters and relies on those client-supplied IDs to return user data. No authorizations checks are done so that any authenticated user can modify or retrieve the identifier, allowing users to act on behalf of all other users.

Business Impact

This can lead to the leakage of sensitive personal data, which can hurt the public reputation of All Ports Tours and lead to fines.

Steps to Reproduce

Step 1: Log into the website

Step 2: Modify the id number in the get request

Remediations

Team-XX recommends the following:

1. Implement strict access control checks to restrict users to only access permitted files and objects. It is recommended to not rely on obscurity or client-side checks.
2. Use random non-guessable identifiers to prevent attackers from guessing the ids of other resources
3. Utilize short-lived, signed, or tokenized URLs when sharing sensitive files or resources instead of static IDs.

References

[CISA - Preventing Web Application Access Control Abuse](#)

[OWASP - IDOR Prevention](#)

M1: File Disclosure

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1213: Data from Information Repositories</u> <u>T1005: Data from Local System</u>	
	Mitigations	<u>M1057: Data Loss Prevention</u> <u>M1022: Restrict File and Directory Permissions</u>	
Affected Scope			

Description

An unauthenticated user can read arbitrary files from the machine's file system without authentication through the API endpoint.

Business Impact

Attackers can exploit this vulnerability to access sensitive information including user credentials, application secrets, system configuration files, and backend code as an unauthenticated user.

Steps to Reproduce

Step 1: Log into the website and view the **API endpoint or URL parameter** that loads the file **X** from the server.

Step 2: Manipulate the parameter to read a sensitive file from the operating system using path traversal characters (../) and read /etc/passwd.

Step 3: Send the request to the modified endpoint and view that the contents of /etc/passwd file are returned.

Remediations

Team-XX recommends the following:

1. Require user authentication on any endpoint that reads internal files
2. Deny absolute paths and any path containing traversal sequences (..) if the API should not be able to read sensitive internal files.
3. Sandbox the application and restrict its file access to known safe directories. This prevents traversal to sensitive system files and directories.

References

[OWASP - Path Traversal](#)

[PortSwigger - What is directory traversal?](#)

M1: Default Credentials in Web Applications

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1078: Valid Accounts</u> <u>T1082: Default Credentials</u>	
	Mitigations	<u>M0801: Access Management</u> <u>M0927: Password Policies</u>	
Affected Scope			

Description

An attacker can gain authorized access to the **HTTP** service by logging in with well-known, and publicly available default credentials. These credentials are weak and very predictable and thus are easily brute-forceable.

Business Impact

An attacker can leverage these default credentials to gain unauthorized access to the **HTTP** service, giving them an initial foothold into the network. This allows them to potentially obtain sensitive information or administrative functionality.

Steps to Reproduce

Step 1: Go to **WEBSITE** on a web browser

Step 2: Login with default credentials found here:

Remediations

Team-XX recommends the following:

1. Immediately changing default credentials for all applications on the network to strong, unique passwords in accordance with a set password policy.
2. Always identify and change default credentials before putting any service or device on the network.

References

[Palo Alto Networks - Multi Factor Authentication](#)

[DigiCert - Creating Password Policy Best Practices](#)

M1: Hard-Coded Credentials in Application

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T0891: Hardcoded Credentials</u> <u>T1078: Valid Accounts</u>	
	Mitigations	<u>M0801: Access Management</u>	
Affected Scope			

Description

The **HTTP** service on **MACHINE1** utilizes hard-coded credentials found in the application's JavaScript source code. This exposes valid credentials to anyone with access to the website, allowing attackers to authenticate as an internal user.

Business Impact

An attacker can leverage these client-side credentials to gain a foothold into the internal network. This can lead to unauthorized access to internal APIs or systems, exposing sensitive data and enabling further compromise.

Steps to Reproduce

- Step 1: Go to **WEBSITE** on a web browser
- Step 2: Press CTRL + U to view the page source code
- Step 3: View hard-coded credentials

Remediations

Team-XX recommends the following:

1. Remove all hard-coded credentials from client-side code. Never include test or debug credentials in files deployed to production, instead use environment variables or secure credential stores to manage secrets safely.
2. Use secure secret management and coding practices by storing all sensitive credentials in environment variables, configuration files outside Webroot, or in centralized secret management systems.
3. Immediately rotate all exposed credentials immediately and audit related systems for unauthorized access.

References

[OWASP - Vulnerabilities: Use of Hard-Coded Credentials](#)

[MITRE CWE-259: Use of Hard-coded Password](#)

M1: AS-REP Roasting

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1558.004 - Steal or Forge Kerberos Tickets: AS-REP Roasting	
	Mitigations	M1047: Audit	

		M1041: Encrypt Sensitive Information M1027: Password Policies
Affected Scope		

Description

An attacker on the network can request authentication data for a user that does not have Kerberos pre-authentication enabled and receive an encrypted ticket from the Domain Controller. This ticket is encrypted with the user's password, and an attacker can then take them offline and use brute-force techniques to crack the password.

Business Impact

This vulnerability can lead to user account compromise without the attacker needing any prior access. Depending on the privileges of the compromised account, it can result in a breach of sensitive data, unauthorized access to sensitive systems, and operational disruption by modifying some services running on the machine.

Steps to Reproduce

Step 1: Enumerate the Active Directory for users with the "Do Not Require Kerberos Preauthentication" feature enabled.

Step 2: Request an AS-REP ticket for the discovered user accounts from the Domain Controller.

Step 3: Export the received hash to a file

Step 4: Crack the hash offline using a tool like hashcat and wordlist like rockyou.txt to recover the password.

Remediations

Team-XX recommends the following:

1. Enable Kerberos pre-authentication for all user accounts in Active Directory. This is the default setting and should not be disabled.
2. Enforce a strong password policy for all service accounts to prevent hash cracking after AS-REP Roasting.

References

[TCM Security - Pre-Authentication in AD Environments](#)

[Microsoft - AS-REP Roasting Detection and Prevention](#)

M1: Local File Inclusion

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1005: Data from Local System</u> <u>T1083: File and Directory Discovery</u>	
	Mitigations	<u>M1057: Data Loss Prevention</u> <u>M1022: Restrict File and Directory Permissions</u> <u>M1048: Application Isolation and Sandboxing</u>	
Affected Scope			

Description

The page parameter under **/documents** is vulnerable to Local File Inclusion, giving an attacker the ability to read any file on the backend server that the www-data user has permission to access.

Business Impact

Attackers can abuse the vulnerability to access sensitive customer and business data, configuration files, databases, and proprietary code stored on the backend system. Attackers will gain more information about the system which they can use to find further vulnerabilities in the system.

Steps to Reproduce

Step 1: Go to **WEBSITE** on a web browser

Step 2: Under the page parameter enter path to a local file that should not be accessible through the website, such as `/etc/passwd`

Step 3: Examine the file contents displayed on the web page

Remediations

Team-XX recommends the following:

1. Avoid passing filenames in user input including direct user input, as well as other data sources that can be manipulated by the attacker, such as cookies.
2. If file access through user input is required, create a whitelist of safe file paths. Or in cases where a whitelist cannot be used (such as arbitrary filenames), store filenames in a database and use table row identifiers in user input.

Reference

[OWASP - Testing for Local File Inclusion](#)

M1: Self-Signed HTTP Certificate

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:H/VA:N/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1587.003 - Develop Capabilities: Digital Certificates</u>	
	Mitigations	<u>M1056: Pre-compromise</u>	
Affected Scope			

Description

The web application on ... uses a self-signed certificate. These provide no value in terms of identity insurance. Furthermore if an attacker finds the certificate's private key they can forge, modify and decrypt traffic.

Business Impact

Poor cryptography opens APT up to legal liabilities and non-compliance fines. Attackers can perform adversary-in-the-middle attacks to steal client data which can lead to fines and a loss of public reputation.

Steps to Reproduce

Step 1: Navigate to the website.

Step 2: Click on the padlock icon.

Step 3: Go to 'Connection is secure' and observe that the certificate is self-signed.

Remediations

Team-XX recommends the following:

1. Generate a valid certificate, either through a third party certificate authority, or a self-hosted one trusted by your organization.
2. Replace the self-signed certificate with this certificate.

References

[Cloudflare - What is an SSL Certificate](#)

M1: Anonymous LDAP Bind

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1482 - Domain Trust Discovery</u> <u>T1087.002 - Account Discovery: Domain Account</u>	
	Mitigations	<u>M1047: Audit</u> <u>M1030 - Network Segmentation</u>	
Affected Scope			

Description

The LDAP (Lightweight Directory Access Protocol) service allows anonymous binding which permits unauthenticated users to connect to Active Directory and query sensitive information. LDAP stores user account details, group memberships, and computer information for the domain.

Business Impact

Attackers can perform reconnaissance without any credentials, gathering information about the internal network, including usernames, group details, and network services. This can be used for further attacks such as password spraying, phishing, and targeted exploitation of user accounts.

Steps to Reproduce

Step 1: Use ldapsearch to connect to the LDAP server and bind to the server without providing a username or password

Step 2: Perform a search query **X** to search for common objects and view the returned query.

Remediations

Team-XX recommends the following:

1. Disable Anonymous LDAP Binds and configure the Active Directory server to reject anonymous bind requests. Do this by modifying the dSHeuristics attribute.
2. Restrict access to the LDAP service to trusted hosts and network segments.

References

[Microsoft Security Advisory ADV190023](#)
[How to check for anonymous LDAP binding](#)

M1: Stored XSS (no cookies)

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.1	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:L/UI:P/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1189: Drive-by Compromise	
	Mitigations	M0818: Validate Program Inputs M1021: Restrict Web-Based Content	
Affected Scope			

Description

User input is stored on the website and then executed as JavaScript when viewed. This allows an attacker to upload a malicious script as user input, which rendered by another user or APT Admin, could alter the website display or be used to phish for user credentials.

Business Impact

This could allow a malicious actor to alter the display of the website through rendering new JavaScript. This can be exploited for example to render a new login page that could be used to phish for other users' credentials and sent back to the attacker.

Steps to Reproduce

1. Create a post with the following payload `<script>alert(1)</script>`.
2. View the post.

Remediations

Team-XX recommends the following:

1. Validate and normalize all user input on the server with a whitelist where possible. Always encode output and never store raw HTML or JavaScript from untrusted user input without sanitization.

2. Implement a Web Application Firewall to block malicious JavaScript payloads.
3. Utilize a strict Content Security Policy to restrict JavaScript sources.

Reference

[Portswigger - Cross Site Scripting Prevention](#)

[OWASP - XSS Attacks](#)

M1: LDAP Signing and Channel Binding Not Enabled

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.1	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:A/AC:L/AT:N/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1557: Adversary in the Middle T1040: Network Sniffing	
	Mitigations	M1041: Encrypt Sensitive Information M0931: Network Intrusion Prevention	
Affected Scope			

Description

LDAP Signing and Channel Binding is not enabled on the system. As a result, LDAP sessions lack integrity and verification, allowing for attackers to perform a man-in-the-middle attack to intercept and manipulate data. Additionally, a relay attack can be performed to intercept network authentication hashes, which can lead to account compromise.

Business Impact

This vulnerability can lead to the compromise of network accounts through a relay attack. This also allows for an attacker to perform a man-in-the-middle attack which will result in compromise of confidentiality and integrity of communication over the network.

Steps to Reproduce

1. Use the ldap_checker module from netexec to check LDAP and Channel Binding settings, given valid LDAP credentials discovered previously.

Remediations

Team-XX recommends the following:

1. Enable LDAP server signing by setting the Domain Controller LDAP server signing requirements policy to *Require signing*
2. Enable LDAP Channel Binding Tokens in Group Policy (GPO) on the Domain Controller

Reference

[Microsoft - LDAP Channel Binding and LDAP Signing Requirements](#)

[Microsoft - How to Enable LDAP Signing](#)

M1: SMTP Open Relay

Matrix Calculation	CVSS Score	Risk
--------------------	------------	------

Impact	Medium	5.3	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1534: Internal Spearphishing</u> <u>T1598: Phishing for Information</u>	
	Mitigations	<u>M1054: Software Configuration</u> <u>M0801: Access Management</u>	
Affected Scope			

Description

The SMTP server allows for unauthorized email transmission, allowing attackers to send targeted spam or malicious phishing emails to ATP employees and customers from the SMTP server.

Business Impact

This vulnerability compromises email system integrity and allows the attacker to potentially phish for sensitive information or credentials through a targeted phishing campaign. An attacker can send out massive amounts of spam or malicious phishing emails, getting the IP to be blacklisted due to high amounts of malicious or spam traffic seen from the server.

Steps to Reproduce

1. `swaks -f user@domain -t user@domain -d email.eml -s 10.0.0.0:25`

Remediations

Team-XX recommends the following:

1. Configure the SMTP server to disable open relay functionality, including setting up proper authentication for email senders and restricting the list of IP addresses allowed to relay emails.
2. Implement additional email security measures such as SPF (Sender Policy Framework), DKIM (Domain Keys Identified Mail), and DMARC (Domain-based Message Authentication, Reporting, and Conformance) to prevent email spoofing and ensure email authenticity.

Reference

DuoCircle - SMTP Open Relay Vulnerability

Higherlogic - SPF, DKIM, DMARC Email Authentication

M1: Missing HTTP security headers

Matrix Calculation		CVSS Score	Risk
Impact	Medium	N/A	Medium
Likelihood	Low		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1189: Drive-by Compromise T1204.001: User Execution - Malicious Link	
	Mitigations	M1021: Restrict Web-Based Content M1050: Exploit Protection	
Affected Scope			

Description

The affected web servers lack the following recommended security headers:

1. X-Frame-Options
2. X-Content-Type-Options
3. Strict-Transport-Security
4. Referrer-Policy
5. Permissions-Policy
6. Content-Security-Policy

These security headers are crucial for hardening web applications from common client-side attacks.

Business Impact

The lack of security headers increases the attack surfaces for the affected hosts, allowing threat actors to exploit client-side vulnerabilities in web applications. These potential attacks can lead to hijacking user accounts by stealing their cookies or credentials. If a privileged account is compromised, sensitive customer and business data can be leaked.

Steps to Reproduce

Step 1: Run Nikto on the affected hosts and observe their security headers.

Remediations

Team-XX recommends the following:

1. Implement recommended security headers in all web applications.
Provided below are the baseline recommendations, and they should be modified as needed to maintain functionality of the websites:
 - a. X-Frame-Options: SAMEORIGIN
 - b. X-Content-Type-Options: nosniff
 - c. Strict-Transport-Security: max-age=31536000; includeSubDomains
 - d. Referrer-Policy: strict-origin-when-cross-origin
 - e. Permissions-Policy: accelerometer=(), camera=(), geolocation=(), gyroscope=(), magnetometer=(), microphone=(), payment=(), usb=()
 - f. Content-Security-Policy: default-src 'self'; object-src 'none'; frame-ancestors 'none'; base-uri 'self'; form-action 'self';
2. Use the [securityheaders](#) scanning tool to verify their implementation.

References

[Mozilla - HTTP Headers](#)

M1: Low LAN Manager Authentication Level

Matrix Calculation		CVSS Score	Risk
Impact	Medium	N/A	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	<u>T1557.001: Adversary-in-the-Middle - LLMNR/NBT-NS Poisoning and SMB Relay</u>	
	Mitigations	<u>M1042: Disable or Remove Feature or Program</u> <u>M1037: Filter Network Traffic</u>	
Affected Scope			

Description

The **domain** is configured with a low LAN Manager authentication level, which allows the use of weak legacy authentication protocols such as NTLMv1 and LM hashing. These outdated protocols are vulnerable to various attacks including pass-the-hash, relay attacks, and offline cracking due to their weak cryptographic implementations compared to modern hashing.

Business Impact

This vulnerability can lead to both **low and high level** accounts being captured and cracked through man in the middle attacks and unauthorized access to **system** through SMB relay attacks, increasing an attacker surface area and allowing them to cause more damage.

Steps to Reproduce

Step 1: Identify the current LAN Manager authentication level

HKLM\SYSTEM\CurrentControlSet\Control\Lsa\LMCompatibilityLevel

Step 2: Run Responder to capture authentication attempts

Python3 responder.py -l eth0

Step 3: Capture the NTLMv1 or LM hashes from authentication traffic

Step 4: Crack the captured hash using hashcat or associated tool to recover plaintext password

Remediations

Team-XX recommends the following:

1. Set the security policy "Network security: LAN Manager authentication level" to "Send NTLMv2 response only. Refuse LM & NTLM" (level 5) on all domain controllers and member systems via Group Policy.
2. Disable LLMNR if possible to prevent LLMNR Poisoning

References

[Microsoft - Network security: LAN Manager authentication level](#)

M1: Exposed DB Data from API

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1567: Exfiltration Over Web Service</u> <u>T1213: Data from Information Repositories</u>	
	Mitigations	<u>M1041: Encrypt Sensitive Information</u> <u>M1035: Limit Access to Resource Over Network</u>	
Affected Scope			

Description

The exposed **API endpoint** allowed unauthorized users to query database information directly without proper authentication.

Business Impact

An attacker can craft API requests to retrieve sensitive information directly from the database, including personally identifiable information (PII), credentials, internal system data, or business-critical information.

Steps to Reproduce

Step 1: Identify **API vulnerable endpoint** through web scanning or Burp Suite
Step 2: Send unauthenticated GET or POST requests to the API endpoint
Step 3: Observe the API responses for sensitive database fields such as email, password, or id

Remediations

Team-XX recommends the following:

1. Implement authentication and authorization on all API endpoints that deal with sensitive information
2. Implement encryption at rest and during transfer for all sensitive data.
3. Enable comprehensive API logging and monitoring.

References

[OWASP - API Security Top 10](#)